

Лабораторно упражнение №3

Методи за защита в компютърните мрежи

Използване на защитна стена срещу сканиране на портове, атаки от тип „груба сила“ и повишаване на сигурността чрез port knocking

1. Кратки сведения

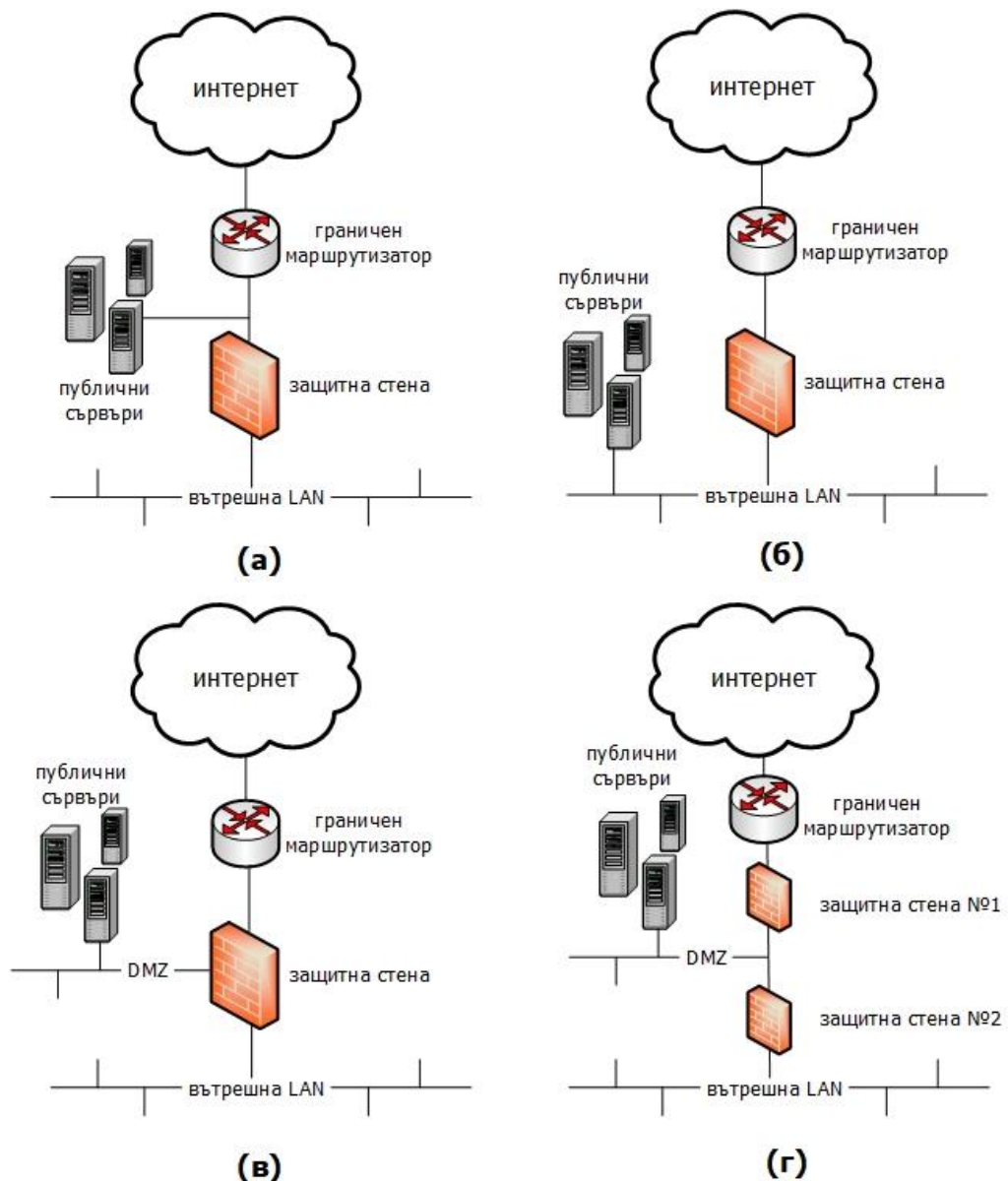
Защитната стена (*англ. Firewall*) представлява мрежова технология, която има за цел да предотврати преминаване на неоторизиран мрежов трафик от една мрежа в друга, извършвайки проверка на пакетите, съобразно предварително дефинирани правила. Най-често защитната стена се разполага на границата между локална мрежа, която трябва да бъде защитена и външна несигурна мрежа (обикновено за достъп до интернет).

Основните функционалности на защитните стени са:

- **Пакетни филтри** – възможността за отхвърляне на връзки на основата на IP адрес, различни флагове или TCP/UDP портове от заглавните части на пакетите.
- **Защита от DoS (Denial of Service), сканиране на портове и неоторизирано прихващане на трафик** – чрез комбинации от пакетни филтри е възможно откриване и отхвърляне на популярни мрежови атаки и методи за неоторизиран достъп.
- **Филтриране на уеб съдържание** – част от защитните стени поддържат функционалности за филтриране на мрежов трафик чрез инспекция на URL и съдържанието на страниците.
- **Поддържане на списъци със забранени IP адреси** – при наличие на забранен мрежов трафик, защитните стени са в състояние автоматично да добавят IP адресите на източниците в списъци, предотвратяващи бъдещ достъп.
- **Генериране на детайлни логове** – една от най-важните особености на защитните стени е възможността за генериране на обстойна информация за всички събития, свързани с преминаващия през интерфейсите им мрежов трафик.
- **Следене на състоянията на връзките** – в допълнение към функциите на пакетните филтри, защитните стени следят състоянията на активните мрежови сесии. Проследяването на връзките има пряко отношение към установяването на TCP сесия (3-way handshake), прехвърлянето на данни и прекратяването на TCP сесия (4-way disconnect)

В своята най-основна реализация, защитната стена има два интерфейса – към вътрешната (сигурна) мрежа и към външната (несигурна) мрежа. В повечето корпоративни мрежи са налични публични сървъри, които трябва да бъдат достъпвани от външни мрежи (напр. HTTP сървъри, SMTP сървъри и т.н.).

На фиг.1.1(а) е показана връзката на публичните сървъри преди защитната стена, като те са изложени на потенциални атаки от интернет. На фиг.1.1(б) те са разположени в рамките на вътрешната локална мрежа, като услугите се предоставят чрез пренасочване на портове и са защитени от директен достъп от интернет. В този случай недостатък се явява фактът, че компроментиран сървър ще даде достъп на неоторизираните лица до ресурсите на вътрешната мрежа.



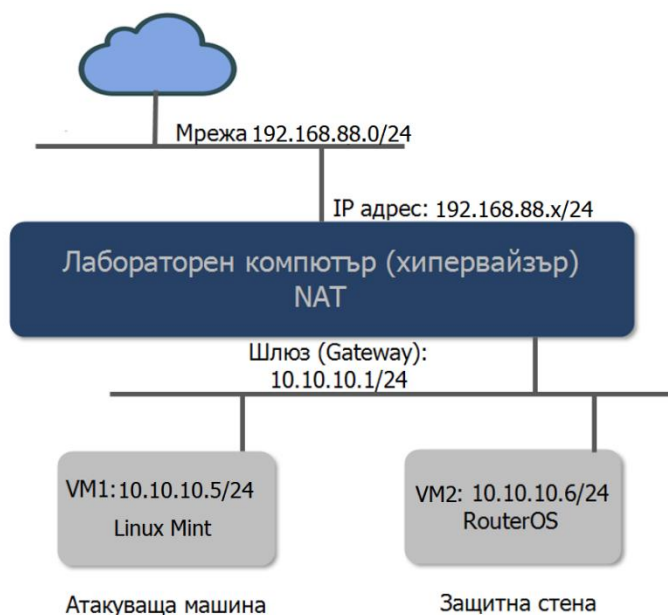
Фиг.1.1. Разположение на защитните стени

Едно решение на тези проблеми се явява поддръжката на повече от два интерфейса в защитните стени (фиг.1.1(в)), което позволява изграждането на междинен сегмент, познат като демилитаризирана зона - **DMZ** (*Demilitarized Zone*). DMZ мрежите се защитават по същия начин, както и вътрешните локални мрежи, но всеки обмен на мрежов трафик между тях се подлага на проверка от защитната стена.

Друго решение е използването на две защитни стени (външна и вътрешна), като DMZ мрежата се разполага между тях. Недостатък е повишената сложност на конфигурация и осъбяването на решението с допълнително устройство.

2. Лабораторна среда

В текущото лабораторно упражнение ще бъдат използвани вече съществуващите виртуални машини – Linux Mint (атакуващ) и MikroTik RouterOS (защитна стена). Целта на упражнението е да бъде извършена конфигурация на защитната стена на маршрутизатора, така че тя да бъде в състояние да открива и отхвърля популярни мрежови атаки.



Фиг.2.1. Виртуализационна среда

За целите на упражнението ще бъдат използвани следните софтуерни приложения в Linux Mint:

- Приложение за сканиране на портове – **nmap**

Приложение за генериране на атака от тип „груба сила“ – **ncrack**

3. Откриване и защита срещу сканиране на портове

Сканирането на портове е популярен метод за събиране на информация относно стартираните мрежови услуги на дадено устройство. На базата на информацията, неоторизирани лица са в състояние да използват уязвимости свързани с конкретните услуги. Текущата задача съдържа конфигурационни правила в защитната стена, целящи откриване и отхвърляне на сканиращи устройства в мрежата.

3.1) Стартирайте виртуалните машини с Linux Mint и RouterOS и влезте в администраторските им профили. За RouterOS използвайте потребителско име **admin** с парола **ma@2025**.

3.2) Тествайте връзката между виртуалните машини посредством командата **ping**.

3.3) Инсталирайте софтуерното приложение **nmap** на виртуалната машина с Linux Mint:
`sudo apt install nmap`

3.4) Стартирайте команден промпт и изпълнете командата:

```
nmap -T5 -A -v 10.10.10.6
```

където:

- `-T<0-5>` задава предефиниран времеви шаблон за времетраенето на сканирането (0 – най-продължително сканиране; 5 – най-бързо сканиране);

- -A включва откриване на операционната система, откриване на версията, скриптовото сканиране и определяне на пътя до целевото устройство чрез traceroute;
- -v определя нивото на детайлност на извежданата информация (verbosity);

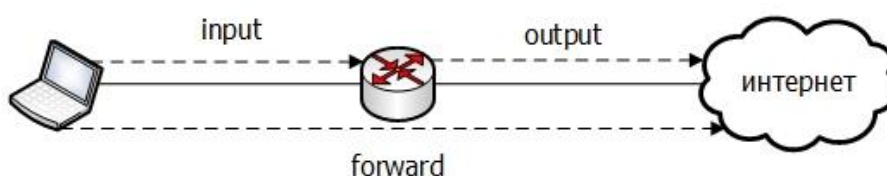
3.5) Разгледайте резултатите след приключване на процеса по сканиране. *Каква информация изведе nmap?*

3.6) С цел защита на RouterOS, изпълнете следната команда (на един ред от терминала) за да добавите правило в защитната стена, което да открива сканиране:

```
/ip firewall filter add chain=input protocol=tcp psd=21,3s,3,1
action=add-src-to-address-list address-list="port-scanners"
address-list-timeout=2m comment="Adding scanners to list" disabled=no
```

където:

- /ip firewall filter add – команда за добавяне на ново правило в защитната стена;
- chain=input – показва, че правилото ще обработва пакети, които са предназначени за самият маршрутизатор. Останалите възможности са chain=forward и chain=output (фиг.3.1). Правила с chain=forward се използват за обработка на пакети, преминаващи през маршрутизатора. Правила с chain=output се използват за пакети, които генерира самият маршрутизатор.



Фиг.3.1. Типове вериги input, output и forward

- protocol=tcp – тип на протокола, за който ще е валидно правилото;
- psd=21,3s,3,1 – параметри определящи границата на чувствителност за регистриране на сканиране.
- action=add-src-to-address-list – определя действието, което ще се извърши при съвпадение на обработвания трафик с правилото. В конкретния случай, IP адреса на източника ще бъде добавен в адресен списък.
- address-list="port-scanners" – задава наименованието на адресния списък.
- address-list-timeout=2m – задава времевия период, през който IP адресът ще фигурира в списъка. За целите на упражнението се използва стойност от 2 минути. В реални условия се препоръчва периодите да бъдат по-големи.
- comment="Adding scanners to list" – коментар, поясняващ действието на правилото;
- disabled=no – правилото влиза в сила веднага след изпълнението на командата.

3.7) Освен правилото, откриващо сканиране, трябва да бъде добавено и правило, което да зададе действие „отхвърляне“ (`action=drop`) на всички пакети от IP адресите, намиращи се в списък „port-scanners“:

```
/ip firewall filter add chain=input src-address-list="port-scanners"  
action=drop comment="Dropping port scanners" disabled=no
```

3.8) Проверете наличието на двете правила чрез командата:

```
/ip firewall filter print
```

3.9) В Linux Mint стартирайте допълнителен терминал (освен този за работа с nmap) и изпълнете командата `ping 10.10.10.6`.

3.10) Извършете процеса по сканиране отново. *Какъв е резултатът? Промени ли се изпълнението на командата ping?*

3.11) Проверете наличието на IP адрес 10.10.10.5 (Linux Mint) в адресния списък посредством командата:

```
/ip firewall address-list print
```

Забележка: Трябва да бъде въведена в рамките на 2 минути от началото на сканирането.

4. Откриване и защита срещу атаки от тип „груба сила“ (brute force)

4.1) Инсталирайте приложението Ncrack във виртуалната машина с Linux Mint: `sudo apt install ncrack`.

4.2) В RouterOS променете паролата на администраторският профил от „ma@2025“ на „123456“:

```
/user set 0 password=123456
```

4.3) В Linux Mint изпълнете командата посочена по-долу. Докато трае процеса, въведете `/system resource monitor` в RouterOS и обърнете внимание на натоварването на централния процесор.

```
ncrack -p 22 -user admin 10.10.10.6
```

където:

- `-p 22` – задава порт на услугата, която ще бъде атакувана. В конкретния случай това е SSH сървър на маршрутизатора.
- `-user admin` – дефинира потребителското име, което ще бъде атакувано.

4.4) Разгледайте резултатите след приключване на изпълнението. *Каква информация изведе приложението?*

4.5) С цел защита на RouterOS, изпълнете следните команди за да добавите правилата в защитната стена, които предотвратяват SSH brute force. Защитата се състои от три етапа (ssh_stage1, ssh_stage2 и ssh_stage3). На всеки етап, IP адресите, генериращи повтарящи се заявки се прехвърлят в нов адресен списък със забрани. Финалният етап прекратява достъпът на адреса за 10 дни. Сложността на правилата произлиза от факта, че легитимни SSH заявки могат да бъдат сметени за атака и да бъде отказан достъп на съответен администратор.

- Влизане в конфигурационното меню на филтрите в защитната стена:

```
/ip firewall filter
```

- Добавяне на правило за отхвърляне на всички заявки на порт 22 от IP адреси в списъка „ssh_blacklist“:

```
add chain=input protocol=tcp dst-port=22 src-address-list=ssh_blacklist  
action=drop comment="drop ssh brute forcers" disabled=no
```

- Финална забрана за достъп (след етап 3):

```
add chain=input protocol=tcp dst-port=22 connection-state=new src-address-  
list=ssh_stage3 action=add-src-to-address-list address-list=ssh_blacklist  
address-list-timeout=10d comment="" disabled=no
```

- Правило за адреси преминаващи от етап 2 към етап 3:

```
add chain=input protocol=tcp dst-port=22 connection-state=new src-address-  
list=ssh_stage2 action=add-src-to-address-list address-list=ssh_stage3  
address-list-timeout=1m disabled=no
```

- Правило за адреси преминаващи от етап 1 към етап 2:

```
add chain=input protocol=tcp dst-port=22 connection-state=new src-address-  
list=ssh_stage1 action=add-src-to-address-list address-list=ssh_stage2  
address-list-timeout=1m disabled=no
```

- Правило за адреси добавяни към етап 1:

```
add chain=input protocol=tcp dst-port=22 connection-state=new action=add-  
src-to-address-list address-list=ssh_stage1 address-list-timeout=1m  
disabled=no
```

4.6) След въвеждане на командите, стартирайте отново brute force атаката. *Какъв е резултатът?*

- 4.7) Проверете наличието на адреса на Linux Mint в адресния списък ssh_blacklist:

```
/ip firewall address-list print
```

4.8) В случай на успешна защита от атаката, премахнете IP адреса от списъка:

```
/ip firewall address-list remove 0
```

4.9) Премахнете всички зададени правила в защитната стена:

```
/ip firewall filter remove [/ip firewall filter find]
```

5. Защита чрез „почукване на портове“ (port knocking)

Специфичен механизъм, свързан със сигурността на мрежовите устройства, който добре илюстрира динамичната работа и едно от приложенията на списъците с адреси в защитната стена, се нарича port knocking. Типичното приложение на механизма се изразява в това портовете за управление на маршрутизатора по подразбиране да бъдат затворени, но след изпълнение на специфична процедура (известна само на администратора), неговият IP адрес да бъде добавен временно в списък, за който портовете са разрешени.

Текущата задача включва реализация на port knocking, която се изразява в последователното изпращане на заявки първо към TCP порт 9000, а в последствие – към TCP порт 6000. Тази комбинация ще отвори временно TCP порт 22 (SSH) с цел осигуряване на достъп на администратора.

5.1) Последователността от команди включва създаване на адресен списък за адреси, изпращащи заявки на порт 9000. В последствие, създаване на нов списък за адреси, изпращащи за порт 6000 и вече фигуриращи в първия списък. В допълнение, порт 22 трябва да бъде забранен по подразбиране за всички останали заявки.

- Влизане в конфигурационното меню на филтрите в защитната стена:

```
/ip firewall filter
```

- Създаване на адресен списък за устройства, изпращащи заявки на TCP порт 9000. Адресният списък ще е валиден в рамките на една минута – ако потребител изпрати заявка на порт 9000 и в рамките на една минута не изпрати на порт 6000, ще бъде премахнат от списъка.

```
add action=add-src-to-address-list address-list="port:9000"  
address-list-timeout=1m chain=input dst-port=9000 protocol=tcp
```

- Създаване на втори адресен списък с наименование „port:6000“:

```
add action=add-src-to-address-list address-list="port:6000" address-list-  
timeout=1m chain=input dst-port=6000 protocol=tcp  
src-address-list="port:9000"
```

- Разрешаване достъпа на всички адреси в списък „port:6000“:

```
add chain=input src-address-list="port:6000" action=accept
```

- Забраняване на достъпа до SSH (порт 22) на всички останали:

```
add chain=input dst-port=22 protocol=tcp src-address-list!="port:6000"  
action=drop connection-state=new
```

5.2) Опитайте се да влезете в RouterOS чрез SSH (*ssh admin@10.10.10.6*). При правилно въвеждане на правилата в защитната стена, достъпът ще ви бъде отказан.

5.3) Посредством приложението nmap, изпълнете командата по-долу в терминала на Linux Mint:

```
nmap -sT -p 9000,6000 10.10.10.6
```

5.4) В рамките на една минута след изпълнението на командата се опитайте да влезете отново в RouterOS чрез SSH. Този път, след последователно генериране на TCP заявки на портове 9000 и 6000, защитната стена временно отваря порт 22 за връзка и осигурява достъп по SSH.